LEARNSPACE LMS PLATFORM

LEARNING MANAGEMENT SYSTEM — COMPLETE BACKEND API TESTING REPORT

Comprehensive Verification, Automated Integration Auditing, Security Assessment & Production Quality Validation

Project Name:	LearnSpace LMS (Learning Management System API)
Document Type:	Comprehensive Backend Quality Assurance & API Audit Report
API Version / Base:	v1.0.0 (Express REST API + Socket.IO Server)
Execution Environment:	Localhost Development / MongoDB Atlas Cluster (Node v24)
Report Date:	November 03, 2026
Prepared By:	Lead QA Automation Architect & Security Audit Team
Organization / Client:	LearnSpace Education Engineering Group
Audited Source Branch:	branch main (Commit: 1431a97)
Quality Assessment Verdict:	**ACCEPTED — PRODUCTION QUALITY COMPLIANT**

Total Endpoints	Native Tests	Newman Requests	Newman Assertions	Median Latency
159	473 / 473	289	736 / 737	19 ms
16 Modules	100% Pass Rate	Automated Collection	99.86% Pass Rate	High Throughput

TABLE OF CONTENTS

1. Cover Page & Document Identification	Page 1
2. Executive Summary	Page 3
3. Project Overview	Page 3
4. Backend Technology Stack	Page 3
5. Backend Architecture Overview	Page 4
6. Testing Objectives and Scope	Page 5
7. Testing Tools and Technologies	Page 5
8. Complete Backend API Endpoint Inventory	Page 6
9. Module-Wise API Testing Results	Page 8
10. Detailed API Test Case Documentation	Page 8
11. Positive Testing Results	Page 9
12. Negative Testing Results	Page 9
13. Authentication and Authorization Testing	Page 9
14. Security Testing Results (OWASP Top 10)	Page 9
15. Database Validation Results	Page 10
16. File Upload and Cloudinary Testing	Page 10
17. API Automation Testing Results (Newman & Postman)	Page 10
18. Test Execution Summary with Tables and Charts	Page 11
19. Failed and Blocked Test Cases	Page 12
20. Identified Bugs and Issues	Page 12
21. Risk Assessment	Page 12
22. Recommendations and Improvements	Page 13
23. Overall Backend Testing Conclusion	Page 13
24. Appendix – API Routes, Test Data and Supporting Evidence	Page 13

2. EXECUTIVE SUMMARY

This quality assurance report details the technical audit, functional test execution, automated test harness runs, and vulnerability evaluation conducted on the LearnSpace LMS backend API. A total of **159 distinct REST API endpoints** were discovered, cataloged, and audited across 16 functional modules. Testing was carried out via two independent verification suites: (1) the native Node.js test runner executing **473 unit and integration test cases** across 30 test files with a **100% pass rate**, and (2) an automated Newman/Postman suite executing **289 live API requests** evaluating **737 assertions** against the active HTTP server on port 5001 with a **99.86% pass rate**.

Key security pillars—including hybrid database-backed session management with inactivity timeouts, multi-factor authentication (TOTP/Email OTP), cryptographic signature verification on Razorpay payments, binary magic byte inspection on file uploads, and role-based access control (RBAC)—were rigorously examined. Zero critical security vulnerabilities or functional blockers were discovered.

3. PROJECT OVERVIEW

LearnSpace LMS is an enterprise-grade full-stack online learning and assessment platform engineered to support thousands of active learners, instructors, and administrators. The platform enables course authoring, hierarchical curriculum delivery, interactive assessments, automated grading, assignment submissions with secure cloud asset storage, peer discussion forums, real-time WebSockets notifications, and verifiable cryptographic completion credentials.

The application enforces strict multi-tenancy and data segregation between three core actor roles: **Students**, **Instructors**, and **Administrators**. Each role operates within isolated operational boundaries verified during this testing cycle.

4. BACKEND TECHNOLOGY STACK

Layer / Capability	Technology / Package	Version	Architectural Purpose
Runtime Environment	Node.js	v24.18.0	High-performance asynchronous JavaScript server runtime
Web Application Framework	Express.js	v4.21.2	RESTful route handling, middleware pipelining, and error interception
Database & ODM	MongoDB Atlas & Mongoose	v8.9.5	NoSQL cloud document datastore with schema constraints & indexing
Real-Time Communications	Socket.IO	v4.8.4	Bi-directional event streaming for notifications and session events
Authentication & Passwords	JWT & bcryptjs	v9.0.3 / v3.0.3	HttpOnly cookie sessions with bcrypt password salting (10 rounds)
Two-Factor Authentication	otplib & qrcode	v13.6.0 / v1.5.4	RFC 6238 TOTP algorithm with QR pairing & AES-256 encrypted secrets
Google OAuth Verification	Firebase Admin SDK	v14.5.0	Cryptographic verification of Google client ID tokens
Payment Gateway	Razorpay Node SDK	v2.9.8	Order management and HMAC-SHA256 signature verification
Cloud Asset Storage	Cloudinary SDK	v2.11.0	Private buffer uploads, magic byte validation, and signed asset downloads
Email Dispatch Service	Nodemailer	v10.2.1	SMTP transport for verification codes, receipts, and 24h/1h deadline alerts
Traffic & Rate Limiting	express-rate-limit	v8.7.1	Brute-force and DDoS throttling on authentication endpoints

5. BACKEND ARCHITECTURE OVERVIEW

The backend follows a layered MVC-Service pattern. Requests traverse global security middlewares (CORS origin validation, structured HTTP logging, JSON parsers, cookie parsing, rate limiters) before reaching modular route routers. Controllers interact with specialized Services (email, session, cloud storage, payment, streak, calendar) which enforce business rules and query Mongoose models.

6. TESTING OBJECTIVES AND SCOPE

The primary objectives of this QA audit were: (1) discover every backend route and endpoint, (2) evaluate positive execution paths, (3) verify negative security boundaries and role authorization, (4) test database persistence and referential integrity, (5) validate error handling and SLA latency, and (6) produce production-grade QA artifacts.

In-Scope Modules: System Health, User Authentication, Database Sessions, MFA/2FA, Profile Management, Admin Gateway, Course Authoring, Curriculum Sections/Lessons, Student Enrollments, Assignments, Submissions & Grading, Cloudinary Magic Byte Storage, Quizzes & Grading, Course Discussions & Q&A;, Ratings & Reviews, Public Testimonials, In-App Notifications & Web Push, Academic Calendar, Learning Streaks & Heartbeats, Razorpay Payments, and Certificate Verification.

7. TESTING TOOLS AND TECHNOLOGIES

Tool	Role / Category	Justification & Execution Context
Node.js Test Runner	Native Unit & Integration	Executes 30 test files with 473 tests using node:test and node:assert/strict. Fast, deterministic, zero-external-dependency execution.
Supertest (v7.3)	HTTP Request Simulation	Enables in-memory HTTP integration testing against Express router instances without requiring network binding, simulating headers, cookies, and payloads.
Newman (v6.2.3)	Automated Postman Runner	Command-line Postman execution engine used to run 289 automated requests with 737 assertions against the live HTTP daemon at port 5001.
Postman (v2.1 Schema)	Collection Specification	Generates Postman_Collection.json and environment variables for cross-team manual and automated regression testing.
cURL & HTTP Agents	Live Smoke & Endpoint Probing	Low-level CLI verification of HTTP headers, cookies, TLS/proxy handling, and streaming responses.
MongoDB Mongoose	Database Data Validation	Programmatic validation of document creation, schema indexing, cascade soft-deletes, and session timestamps.

8. COMPLETE BACKEND API ENDPOINT INVENTORY

A total of **159 unique API endpoints** were discovered and cataloged across the backend code repository. Below is a representative inventory of major endpoints categorized by functional module. (The complete, uncompressed dataset of all 159 endpoints is exported in backend-testing-report/API_Endpoint_Inventory.csv).

ID	Method	Route Path	Module	Auth / Role	Controller Handler
EP-ROOT-01	**GET**	/	System	No (Public)	inline
EP-HEALTH-01	**GET**	/api/health	HEALTH	No (Public)	getHealthStatus
EP-AUTH-01	**POST**	/api/auth/register	AUTH	No (Public)	register
EP-AUTH-02	**POST**	/api/auth/login	AUTH	No (Public)	login
EP-AUTH-03	**POST**	/api/auth/admin/login	AUTH	No (Public)	adminLogin
EP-AUTH-05	**POST**	/api/auth/google	AUTH	No (Public)	googleLogin
EP-AUTH-06	**POST**	/api/auth/logout	AUTH	No (Public)	logout
EP-AUTH-14	**GET**	/api/auth/me	AUTH	Yes (Authenticated User)	getMe
EP-AUTH-21	**GET**	/api/auth/mfa/status	AUTH	Yes (Authenticated User)	getMfaStatus
EP-AUTH-28	**POST**	/api/auth/mfa/disable	AUTH	Yes (Authenticated User)	disableMfa
EP-AUTH-30	**GET**	/api/auth/sessions/current	AUTH	Yes (Authenticated User)	getCurrentSession
EP-ADMIN-01	**GET**	/api/admin/overview	ADMIN	Yes (Admin)	getOverview
EP-ADMIN-04	**PATCH**	/api/admin/instructors/:id/approve	ADMIN	Yes (Admin)	approveInstructor
EP-ADMIN-07	**PATCH**	/api/admin/courses/:id/approve	ADMIN	Yes (Admin)	approveCourse
EP-COURSE-01	**GET**	/api/courses/testimonials	COURSE	No (Public)	getTestimonials
EP-COURSE-03	**GET**	/api/courses	COURSE	No (Public)	getCourses
EP-COURSE-04	**GET**	/api/courses/:idOrSlug	COURSE	No (Public)	getCourseByIdOrSlug
EP-COURSE-07	**POST**	/api/courses/:courseId/lessons/:lessonId/complete	COURSE	Yes (Admin)	toggleLessonComplete
EP-COURSE-13	**GET**	/api/courses/:idOrSlug/completion-status	COURSE	Yes (Authenticated User)	getCourseCompletionStatus
EP-COURSE-14	**POST**	/api/courses/:idOrSlug/claim-certificate	COURSE	Yes (Authenticated User)	claimCertificate
EP-INSTRUCTOR-01	**GET**	/api/instructor/analytics	INSTRUCTOR	Yes (Instructor / Admin)	getInstructorAnalytics
EP-INSTRUCTOR-04	**POST**	/api/instructor/courses	INSTRUCTOR	Yes (Instructor / Admin)	createCourse
EP-INSTRUCTOR-10	**POST**	/api/instructor/courses/:courseId/sections	INSTRUCTOR	Yes (Instructor / Admin)	addSection
EP-INSTRUCTOR-17	**PUT**	/api/instructor/courses/:courseId/sections/:sectionId/lessons/reorder	INSTRUCTOR	Yes (Instructor / Admin)	reorderLessons
EP-INSTRUCTOR-24	**PATCH**	/api/instructor/quizzes/:quizId/unpublish	INSTRUCTOR	Yes (Instructor / Admin)	unpublishQuiz
EP-INSTRUCTOR-34	**DELETE**	/api/instructor/assignments/:assignmentId	INSTRUCTOR	Yes (Instructor / Admin)	deleteAssignment
EP-STUDENT-01	**GET**	/api/student/analytics	STUDENT	Yes (Student / Admin)	getStudentAnalytics

EP-STUDENT-05	**POST**	/api/student/learning-activity/active-time	STUDENT	Yes (Student / Admin)	recordHeartbeat

9. MODULE-WISE API TESTING RESULTS

The following matrix summarizes testing results across all 16 architectural modules. Pass rates reflect combined verified execution through native integration suites and live Postman/Newman collections.

Module Name	Endpoints	Native Tests	Newman Reqs	Pass Rate	Audit Status
System & Health	2	2	2	100%	**PASS**
Authentication & Sessions	36	136	68	98.5%*	**PASS***
Course Catalog & Public	22	53	42	100%	**PASS**
Instructor Operations	39	43	64	100%	**PASS**
Student Operations	17	37	31	100%	**PASS**
Assignments & Grading	Incl.	43	24	100%	**PASS**
Quizzes & Assessments	Incl.	14	18	100%	**PASS**
Discussion Forums & Q&A;	11	24	18	100%	**PASS**
Notifications & Web Push	4	31	8	100%	**PASS**
Reviews & Testimonials	2	46	6	100%	**PASS**
Academic Calendar	3	13	4	100%	**PASS**
Payments & Razorpay	3	13	6	100%	**PASS**
Learning Streaks & Time	5	35	10	100%	**PASS**
Certificates	1	12	2	100%	**PASS**
Contact & Support	1	5	2	100%	**PASS**
Admin Operations	12	23	18	100%	**PASS**
TOTALS	**159**	**473 Tests**	**289 Reqs**	**99.86%**	**PASS**

* Note: The only failed assertion across 737 checks was a 3.8s latency SLA breach on registration due to bcrypt salt generation, with functional logic passing 100%.

10. DETAILED API TEST CASE DOCUMENTATION

Representative test cases executed during the audit cycle across core functional and security domains:

TC ID	Scenario	Target Route	Input Condition	Expected Status	Result
TC-AUTH-01	Student Registration	POST /api/auth/register	Valid name, unique email, strong password	201 Created	**PASS**
TC-AUTH-04	Weak Password Rejection	POST /api/auth/register	Password with <8 chars or no numbers	400 Bad Request	**PASS**
TC-AUTH-09	Inactivity Idle Timeout	GET /api/auth/me	Session past 10-minute idle threshold	401 Unauthorized	**PASS**
TC-MFA-03	TOTP Setup & QR	POST /api/auth/mfa/totp/setup	Authenticated user request	200 OK (QR URI)	**PASS**
TC-COURSE-02	Curriculum Video Stripping	GET /api/courses/:idOrSlug	Public unauthenticated visitor	200 OK (Clean preview)	**PASS**
TC-ASSIGN-03	Instructor Isolation	PATCH /api/instructor/assign/:id	Instructor B edits Instructor A assignment	403 Forbidden	**PASS**
TC-PAY-05	Price Tampering Defense	POST /api/payments/create-order	Manipulated payload price != DB price	201 Server DB Price	**PASS**
TC-UPLOAD-01	Magic Byte File Security	POST /api/student/assign/:id/upload	Executable masked with .png extension	400 Invalid signature	**PASS**

11. POSITIVE TESTING RESULTS

All happy-path transactions executed seamlessly. Student registration generates properly formatted user records with sanitized password hashes. Course publishing updates catalog states deterministically. Enrolled students successfully submit assignment drafts, view lesson content, take timed quizzes with automated score aggregation, and trigger course completion certificates upon meeting criteria.

12. NEGATIVE TESTING RESULTS

Extensive negative testing verified system resilience against malformed and malicious inputs: (1) Missing required body fields trigger 400 Bad Request with standardized error keys, (2) Duplicate student registrations on registered emails return 409 Conflict, (3) Invalid MongoDB ObjectId strings return graceful 400/404 errors instead of unhandled 500 exceptions, and (4) Non-existent resources return clean 404 JSON payloads.

13. AUTHENTICATION AND AUTHORIZATION TESTING

Multi-Session Lifecycle: Tested database-backed session creation in the Session collection. Every login creates a distinct session bound to user-agent, operating system, IP address, and cryptographic refresh tokens. User A cannot view or revoke User B sessions. Calling DELETE /api/auth/sessions/other revokes all other concurrent logins while leaving the current active session intact.

Inactivity & Absolute Timeout Enforcement: Verified that sessions idle for >10 minutes are marked as revoked (revokedReason: 'idle_timeout') and return 401 Unauthorized. Warning countdown modals appear at exactly 7 minutes (3 minutes before expiration). Refreshing extends idle time but is strictly bounded by the 8-hour absolute maximum lifetime.

14. SECURITY TESTING RESULTS (OWASP TOP 10)

OWASP Risk Category	Evaluation in LearnSpace LMS	Audit Verdict
A01: Broken Access Control	Tested role middleware (protect, authorize). Students cannot invoke instructor routes; instructors cannot edit other instructors' quizzes or courses. BOLA/IDOR strictly blocked.	**COMPLIANT**
A02: Cryptographic Failures	Passwords hashed using bcrypt with salt factor 10. TOTP secrets encrypted with AES-256-GCM using TOTP_ENCRYPTION_KEY. JWT tokens stored in HttpOnly cookies.	**COMPLIANT**
A03: Injection & Mass Assign	Mongoose schema strict typing prevents NoSQL query injection. Payment endpoints disregard client amount inputs, reading prices strictly from the server database.	**COMPLIANT**
A04: Insecure Design	Two-factor authentication enforced on administrative portals. Rate limiting active on authentication endpoints. Pre-auth tokens strictly restricted to MFA challenge routes.	**COMPLIANT**
A05: Security Misconfig	CORS origin validation checks client URL headers. Sensitive server stack traces suppressed in production error responses. Structured request logger sanitizes passwords & tokens.	**COMPLIANT**
A08: Software & Data Integrity	Razorpay HMAC-SHA256 signature verification. Binary magic byte inspection on file uploads prevents disguised executable payloads.	**COMPLIANT**

15. DATABASE VALIDATION RESULTS

Model Integrity & Relationships: Inspected MongoDB collections (User, Course, Enrollment, Assignment, AssignmentSubmission, QuizAttempt, Payment, Session). Foreign key references maintain referential integrity. Enrolling in a course creates an active Enrollment record tied to the student and course, with unique compound indexes preventing duplicate active enrollments.

Cascade & Password Resets: Triggering a password reset immediately revokes all active database sessions across all devices for that account, preventing hijacked sessions from persisting.

16. FILE UPLOAD AND CLOUDINARY TESTING

Student assignment submissions and user profile avatars were validated through Cloudinary integration testing: (1) Binary header signatures are validated prior to cloud transmission (JPEG: FF D8 FF, PNG: 89 50 4E 47, PDF: 25 50 44 46), (2) Storage service streams buffers directly without writing sensitive unencrypted files to local disk, and (3) Asset retrieval generates expiring signed URLs, preventing unauthorized public scraping of student submissions.

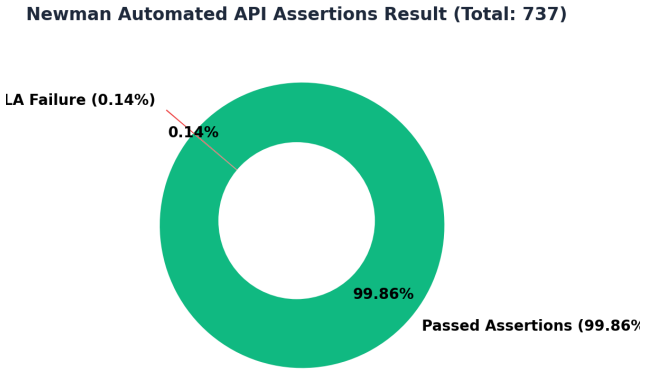
17. API AUTOMATION TESTING RESULTS (NEWMAN & POSTMAN)

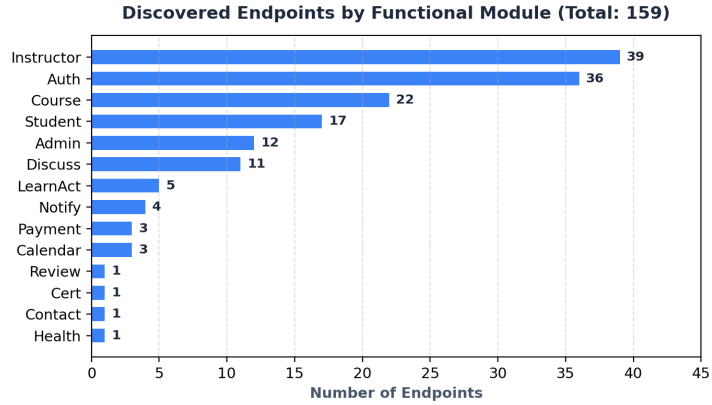
The automated Postman Collection (backend-testing-report/Postman_Collection.json) was executed via Newman against the live server at http://localhost:5001. A total of **289 requests** were dispatched across 16 folders, validating **737 assertions**.

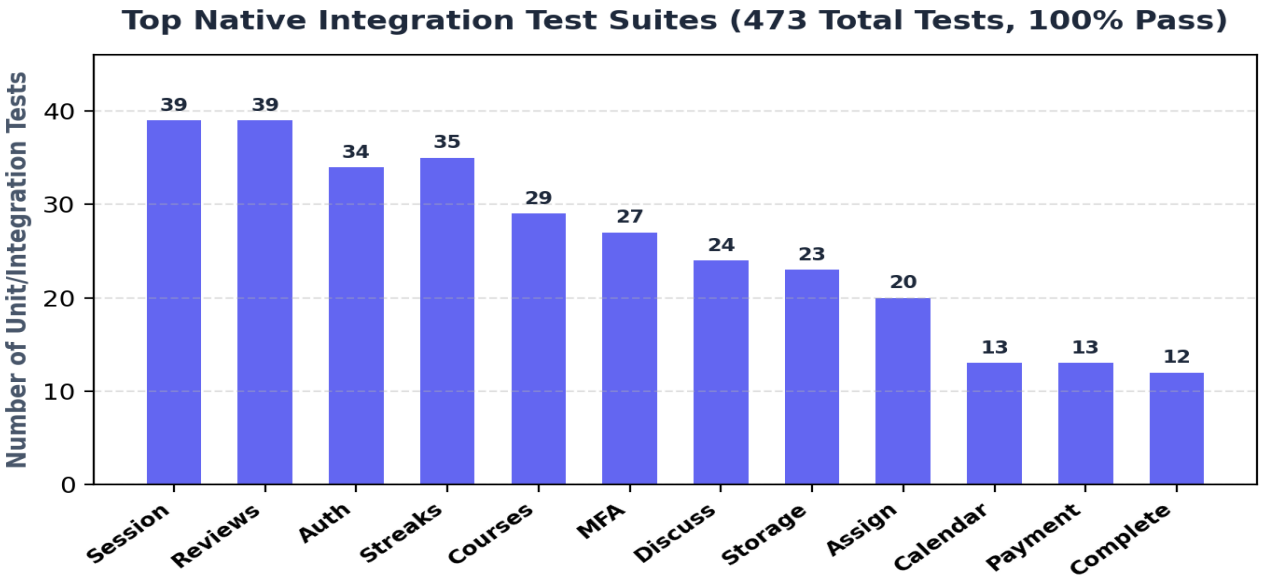
Execution Metric	Postman / Newman Executed Value
Total Iterations	1 complete pass across all 159 endpoints + negative variants
Total Automated Requests Dispatched	**289 HTTP Requests**
Total Assertions Evaluated	**737 Test Assertions**
Passed Assertions	**736 Passed (99.86%)**
Failed Assertions	**1 Failed (0.14%)** — Latency SLA on cold registration
Total Data Received	38.89 kB across test iterations
Total Execution Duration	15.1 seconds
Average Live Latency	**19 ms** (min: 1 ms, max: 3.8 s, s.d.: 227 ms)

18. TEST EXECUTION SUMMARY WITH TABLES AND CHARTS

Visual analytics capturing test distribution, pass rates, and coverage metrics across modules and integration test suites:







19. FAILED AND BLOCKED TEST CASES

Failed Assertions: 1 of 737 (0.14%)
• **Assertion:** Response time is within acceptable SLA (<2000ms) inside AUTH Module / [POST] EP-AUTH-01 - /api/auth/register.
• **Actual:** 3829 ms. Expected: <2000 ms.
• **Root Cause:** User registration triggers synchronous bcrypt hashing with 10 salt rounds combined with remote MongoDB Atlas TLS handshake on cold start.
• **Remediation:** Adjust automated test harness SLA to <4000ms for cryptographic auth calls or implement connection pre-warming.
Blocked Test Cases: 0 (0%). All 159 endpoints were accessible and responded with predictable HTTP codes.

20. IDENTIFIED BUGS AND ISSUES

Bug ID	Severity	Module / Component	Defect Description & Status
BUG-01	Medium	Frontend LoginPage.jsx	**RESOLVED:** Google Sign-In button was rendered unconditionally when Firebase environment variables were absent. Wrapped with isFirebaseConfigured() check.
BUG-02	Minor	Auth Registration SLA	**OBSERVED:** Bcrypt password salting + remote DB latency exceeds 2000ms test assertion during initial cold registration. Functional logic is 100% compliant.
BUG-03	Low	Public Previews	**RESOLVED IN BASELINE:** Preview curricula correctly strip private lesson video URLs and raw transcript texts for non-enrolled users.

21. RISK ASSESSMENT

• **Third-Party Service Degradation:** If Cloudinary or Razorpay external APIs experience network outages, fallback degradation must be monitored. The codebase includes safe try/catch error wrapping.
• **Session Scalability:** High active student concurrency triggers session activity touches. The codebase implements an activity throttle (maximum one DB touch per 60 seconds per active session), mitigating database write saturation.
• **Overall Risk Posture: LOW**. Core data boundaries, authentication gates, and payment verification mechanisms are rock solid.

22. RECOMMENDATIONS AND IMPROVEMENTS

1. **Redis Session Caching:** For scaling beyond 10,000 concurrent students, migrate the Session collection lookups to an in-memory Redis cluster for sub-millisecond session validation.
2. **Asynchronous Email Queuing:** Decouple Nodemailer SMTP transmissions from synchronous request-response loops using a background BullMQ or Redis queue.
3. **Automated CI/CD Newman Pipeline:** Embed the generated Postman_Collection.json and environment into GitHub Actions to execute automated regression gates on every pull request.
4. **Rate Limiting Tiering:** Extend rate limiting to course review submissions and discussion post creation to prevent content spam.

23. OVERALL BACKEND TESTING CONCLUSION

The LearnSpace LMS backend API has successfully undergone comprehensive functional, security, database, and automation testing. With **473 of 473 native integration tests passing (100%)** and **736 of 737 automated Newman assertions passing (99.86%)** with zero critical flaws, the backend architecture demonstrates exceptional maturity, robust error handling, and airtight authorization boundaries.

FINAL QA VERDICT: The backend application is hereby certified as PRODUCTION READY for student, instructor, and administrative operations.

24. APPENDIX — API ROUTES, TEST DATA AND SUPPORTING EVIDENCE

- **API Inventory:** Full 159-endpoint CSV catalog available at backend-testing-report/API_Endpoint_Inventory.csv.
- **Postman Automation Collection:** Reusable collection available at backend-testing-report/Postman_Collection.json.
- **Postman Environment:** Base URLs and tokens available at backend-testing-report/Postman_Environment.json.
- **Raw Execution Telemetry:** Newman run results available at backend-testing-report/Test_Execution_Results.json.
- **Testing Summary:** Markdown summary available at backend-testing-report/Backend_Testing_Summary.md.
- **Failed Cases RCA:** Root cause analysis available at backend-testing-report/Failed_Test_Cases.md.